

Warsaw, November 30, 2023

Decision

DKN.5131.6.2023

DECISION

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended), Article 7(1) and Articles 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57(1)(a) and (h), Article 58(2)(e) and (i), Article 83(1) and (2), Article 83(4)(a) in connection with Article 33(1) and Article 34(1), (2), and (4) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by ENEA S.A. based in P. [street...], the President of the Personal Data Protection Office,

1) finds that ENEA S.A. based in P. [street...] has violated the provisions of:

- a) Article 33(1) of Regulation 2016/679, consisting of failing to notify the President of the Personal Data Protection Office of a personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach,
- b) Article 34(1) of Regulation 2016/679, consisting of failing to inform the data subject without undue delay about the personal data breach,

imposes on ENEA S.A. based in P. [street...] an administrative fine of 282,960 PLN (in words: two hundred eighty-two thousand nine hundred sixty zlotys),

2) orders ENEA S.A. based in P. [street...] to notify - within 3 days from the date of delivery of this decision - the person whose data was disclosed in connection with the sending of contract no. [...] to an improper recipient, about the personal data breach in order to provide her with the information required under Article 34(2) of Regulation 2016/679, namely:

- a) a description of the nature of the personal data breach;
- b) the name and contact details of the data protection officer or another contact point from which more information can be obtained;
- c) a description of the possible consequences of the personal data breach;
- d) a description of the measures taken or proposed by the controller to address the breach - including measures to mitigate its potential negative effects.

Justification

To the President of the Personal Data Protection Office, hereinafter also referred to as the "President of UODO" or "supervisory authority", on [...] January 2023, a letter was received from the District Court in P. containing information about an ongoing case brought by an individual (hereinafter Data Subject or Client of the Company) against ENEA S.A. based in P., hereinafter also referred to as the "Company" or "Controller", for a claim due to a violation of personal data protection regulations. From the aforementioned letter, it follows that the violation consisted of sending correspondence containing the contract between the parties dated [...] March 2020 to an incorrect address, which resulted in the disclosure to an unauthorized person, who received the correspondence, of the personal data of the Company's Client.

In connection with the above, by letter dated January 31, 2023, the President of UODO, based on Article 58(1)(a) and (e) of Regulation 2016/679, requested the Company to clarify whether an analysis of the event regarding the risk of violation of the rights and freedoms of natural persons necessary to assess whether there was a personal data breach requiring notification of the President of UODO and the data subject had been conducted in connection with the sending of the above-mentioned contract to an unauthorized recipient. This letter also included information about the content of Article 33(1) and

(3) of Regulation 2016/679 and possible ways to report a personal data breach. Furthermore, the Company was informed about the obligation to notify the data subject of the breach, resulting from Article 34(1) of Regulation 2016/679. In response to the above, the Company, by letter dated February 21, 2023, reference no. [...] confirmed that the personal data breach consisting of sending a shipment containing the contract no. [...] signed by the Data Subject to another client of the Company had occurred. The Company became aware of the occurrence of the aforementioned event on [...] November 2020, when it received a letter from the Client's attorney. As a result of the above event, the confidentiality of one person's data was breached in terms of: name, surname, PESEL number, contact details, and email address. The person who mistakenly sent the correspondence containing the personal data of the Company's Client to the wrong address (as indicated in the Company's explanations) was

of the data protection officer or designation of another contact point from which more information can be obtained;

b) a description of the possible consequences of the personal data breach;

c) a description of the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

In light of the above, the President of the Personal Data Protection Office concluded that ENEA S.A. failed to comply with the obligations set forth in Articles 33 and 34 of Regulation 2016/679 regarding the notification of a personal data breach to the supervisory authority and the affected individuals.

The President of the Personal Data Protection Office decided to impose an administrative fine on ENEA S.A. for the infringement of the provisions of the GDPR, taking into account the nature, gravity, and duration of the infringement, as well as the number of affected individuals and the level of damage caused.

The decision also considered the measures taken by ENEA S.A. to mitigate the risks associated with the breach, as well as the company's cooperation with the supervisory authority during the proceedings.

The fine imposed on ENEA S.A. is intended to ensure compliance with data protection regulations and to serve as a deterrent to prevent similar breaches in the future.

This decision is subject to appeal in accordance with applicable law.

****Conclusion****

In summary, ENEA S.A. did not fulfill its obligations under the GDPR regarding the notification of a personal data breach, which resulted in the initiation of administrative proceedings and the imposition of a fine. The company is encouraged to enhance its data protection measures and ensure compliance with legal requirements to protect the rights and freedoms of individuals.

of the measures taken and, on the other hand, ensure that individuals are informed and can take appropriate actions to protect their rights and freedoms.

****1. Data Protection Obligations****

a) The designation of a contact point from which more information can be obtained;

b) A description of the possible consequences of a breach of personal data protection;

c) A description of the measures taken or proposed by the administrator to address the breach of personal data protection, including, where appropriate, measures to minimize its potential negative effects.

From the analysis of the above provisions, it follows that depending on the level of risk of infringement of the rights or freedoms of natural persons that the administrator is dealing with, their obligations towards the supervisory authority, as well as towards the individuals whose data is concerned, differ. If, as a result of the analysis, the administrator determines that the likelihood of a risk to the rights or freedoms of natural persons is low, they are not obliged to report the breach to the President of the Personal Data Protection Office (UODO). The indicated breach must only be recorded in the internal register of breaches. In the case of identifying a risk of infringement of the rights or freedoms of natural

persons, the administrator is obliged to report the breach of data protection to the President of UODO, as well as to make an entry in the internal register of breaches. The occurrence of a high risk of infringement of the rights or freedoms of natural persons, in addition to the entry in the register of breaches, requires the administrator to take appropriate actions, both towards the supervisory authority (reporting the data protection breach) and also towards the individuals whose data is concerned.

In the case of breaches of personal data protection that may cause a high risk of infringement of the rights or freedoms of the individual whose data is concerned, Regulation 2016/679 introduces an additional obligation for the administrator to promptly notify the data subject, unless they have taken preventive measures before the breach occurred or remedial actions after the breach occurred (Article 34(3) of Regulation 2016/679).

As follows from the above, in the event of the administrator detecting a breach of personal data protection, it is first necessary to analyze the risk of infringement of the rights or freedoms of natural persons. The administrator is exempt from the obligation to notify the supervisory authority of the breach if the conducted assessment shows that there is at most a low probability of the occurrence of a risk of infringement of the rights or freedoms of natural persons. However, it should be borne in mind that the supervisory authority may request the administrator to justify the decision not to report the breach; therefore, the conclusions from the conducted analysis should be recorded in the internal register of breaches. It is worth recalling that in the Guidelines of the European Data Protection Board (EDPB) No. 9/2022^[1] adopted on March 28, 2023, hereinafter referred to as Guidelines 9/2022, there are recommendations regarding the reporting of breaches of personal data protection to the supervisory authority.

It should be emphasized that the assessment of the risk of infringement of the rights or freedoms of a natural person should be made from the perspective of the affected individual, not the interests of the administrator. This is particularly important because based on the notification of a breach of personal data protection, the individual can assess for themselves whether, in their opinion, the security incident may have negative consequences for them and take appropriate remedial actions. Also, based on the information provided by the administrator regarding the description of the nature of the breach and the measures taken or proposed to remedy the breach, the individual can assess whether, after the breach occurred, the data administrator still provides assurance of the proper processing of their personal data in a manner that ensures their security. The lack of notification of a breach of personal data protection to the individual in the case of a high risk of infringement of their rights or freedoms deprives them not only of the possibility of an appropriate response to the breach but also of the ability to make an independent assessment of the breach, which, after all, concerns their personal data and may have serious consequences for them. On the other hand, the lack of reporting a breach of personal data protection deprives the supervisory authority of the ability to respond appropriately to the breach, which involves not only assessing the risk of infringement of the rights or freedoms of the individual but also, in particular, verifying whether the administrator has taken appropriate measures to remedy the breach and minimize the negative effects for the individuals whose data is concerned, as well as whether they have implemented appropriate security measures to minimize the risk of a recurrence of the breach.

Reporting breaches of personal data protection by administrators is therefore an effective tool contributing to a real improvement in the security of personal data processing. By reporting a breach to the supervisory authority, administrators inform the President of UODO whether, in their assessment, there is a high risk of infringement of the rights or freedoms of the individuals whose data is concerned and – if such a risk exists – whether they have provided appropriate information to the individuals affected by the breach. In justified cases, they may also provide information that notification is not necessary in their opinion due to the fulfillment of the conditions specified in Article 34(3)(a) and (b) of Regulation 2016/679. The President of UODO verifies the assessment made by the administrator and may – if the administrator has not notified the individuals whose data is concerned – request such notification. Reporting breaches of personal data protection allows the supervisory authority to respond

appropriately, which can mitigate the effects of such breaches, as the administrator has an obligation to take effective actions to ensure the protection of individuals and their personal data, which on one hand allows for the control of the effectiveness of the measures taken and, on the other hand, ensures that individuals are informed and can take appropriate actions to protect their rights and freedoms. previous solutions, and on the other hand, the assessment of modifications and improvements aimed at preventing irregularities analogous to those covered by the breach. The notification of natural persons about the breach provides the opportunity to convey information to these individuals regarding the risks associated with the breach and to indicate actions that they can take to protect themselves from potential negative consequences of the breach (this allows the individual to make an independent assessment of the breach in the context of the possibility of materializing negative consequences for that individual and to make a decision on whether to take or not take remedial actions).

ENEA S.A., due to the scale and subject of its activities, i.e., the trade and generation of electricity, processes personal data of a very large number of customers with whom it enters into, among other things, electricity sales agreements. In the case under consideration, the personal data of the Company's Client contained in the agreement between the parties, i.e., the PESEL number, first and last name, contact details, and email address, were accessed by an unauthorized person. There is no doubt that based on the disclosed data, the Data Subject can be easily identified. Furthermore, data related to the fact of entering into the agreement and its content were disclosed. Consequently, the assessment of the breach conducted by the administrator in terms of the risk of violation of the rights or freedoms of natural persons, necessary to determine whether there has been a breach of data protection resulting in the obligation to notify the President of the Personal Data Protection Office (Article 33(1) and (3) of Regulation 2016/679) and the individuals affected by the breach (Article 34(1) and (2) of Regulation 2016/679), should, as it should be emphasized once again, be made through the lens of the person affected by the breach. Accidental disclosure of personal data to even one identified person can lead to an increase in the scale of the breach and thus the risk of violation of the rights or freedoms of the person to whom the data pertains. At the same time, the Administrator did not demonstrate, in accordance with the principle of accountability referred to in Article 5(2) of Regulation 2016/679, that its client, to whom the agreement containing the Client's data was sent, could be considered a so-called trusted recipient. From the explanations provided by the Company in a letter dated March 22, 2023, it follows that it refrained from reporting the breach to the supervisory authority because it "qualified the breach as characterized by a low probability of resulting effects in the form of a risk of violation of the rights or freedoms of natural persons." The risk assessment was based on the belief that the person who came into possession of the agreement is a so-called "honest finder," as they "demonstrated awareness of personal data protection, took the initiative to contact the Client, and also provided their identity and contact details." Taking the above into account, the Company assessed that "it is unlikely that sending the Client's agreement to the Recipient's address would cause further risk (apart from the Recipient's mere acquaintance with the Client's data) of violating the rights or freedoms of the Client."

To better illustrate cases of breaches of personal data protection, resulting in accidental disclosure of data to an unauthorized person, reference should be made to Guidelines 9/2022, which indicate a case of a breach concerning data confidentiality involving the accidental disclosure of personal data to a third party or another recipient in a situation where such data is accidentally sent to the wrong department of the organization or to a supplier organization from which the administrator uses services. The administrator has grounds to then consider the unauthorized recipient as trusted, as they maintain ongoing relations with such an entity, know the procedures applied by them, and can trust the recipient enough to reasonably expect that the recipient will not read the mistakenly sent data or gain access to it, as well as fulfill the instruction to return it. Even in a situation where access to the data has been gained, the administrator may still trust the recipient not to take any inappropriate actions and to promptly return the data to the administrator. As further indicated by EROD, in the described case, the administrator in the risk assessment conducted following the breach may take into account the fact that the recipient is a trusted person. However, such a situation does not occur in the case under discussion. Another client of the Company, to whom correspondence containing the personal data of

the Data Subject was mistakenly directed, does not maintain relations with the Company that would allow for the assumption that they are a trusted recipient, in accordance with the above position of EROD.

Referring to the above, it should be noted that the Company's position is incomprehensible, as it was already inferred from the content of the letter from the Client's attorney that the recipient is an "honest finder," and based on this belief, the risk assessment was made, completely disregarding the fact that there was a disclosure of the Client's personal data to an unauthorized person. The fact that the data was disclosed to only one identified person is also irrelevant. In the case of delivering mistaken correspondence to a person known to the Administrator, e.g., another client who informed the Data Subject about the Company's mistake, there is no guarantee that the intentions of that person will not change. The time that elapsed from the day the incident occurred to the moment the breach was identified is also significant. More than 4 months passed between the date of sending the agreement containing the personal data of the Company's Client to the address of an unauthorized person ([...] July 2020) and the notification received from the Client's attorney ([...] November 2020), during which time it was possible for the unauthorized use of this personal data for purposes violating her rights and interests. The assessment above is also not influenced by the fact of obtaining a statement from the inappropriate recipient regarding the retention.

confidentiality of the Company's Client's data and that he has not disclosed it to third parties, nor does he possess copies of that data. There is no certainty that before recording the statement, this person did not make a copy or did not preserve the personal data contained in the content of the agreement in another way, for example, by writing it down. The Company also has no actual means of verifying the statement that the unauthorized recipient did not disclose the Company's Client's data to third parties nor does he possess copies of that data. According to the Company's explanations, the label on the shipment correctly indicated the name and surname of the Company's Client, so the person to whom this shipment was addressed could have realized that the correspondence was not intended for them, and yet opened the envelope and became acquainted with its contents. Similarly, the Provincial Administrative Court in Warsaw expressed itself in a judgment dated January 21, 2022, case file II SA/Wa 1353/21, stating that "(...) there is no certainty that before these actions, this person did not make, for example, a photocopy or did not preserve the personal data contained in the document in another way, for instance, by writing it down. The mere execution of the actions indicated in the statements made by the Third Party - the unauthorized recipient - does not guarantee that such a person's intentions will not change now or in the future, and any consequences of using such categories of data may be significant for the individuals whose data has been violated." It should be emphasized once again that the statement made by the unauthorized recipient does not determine that it is unlikely that this violation resulted in a risk of infringement of the rights or freedoms of natural persons and does not exclude the assumption that there was a high risk of infringement of the rights or freedoms of the person to whom the data pertains. It should be pointed out again that personal data was disclosed to an unauthorized recipient, which means that there was a breach of security leading to the unauthorized disclosure of personal data; the unauthorized recipient cannot be considered a "trusted recipient," and the scope of this data determines that there was a high risk of infringement of the rights or freedoms of natural persons. From the letter dated [...] January 2023, which the District Court in P. sent to the President of UODO, it follows that the Company's Client has filed a compensation claim due to the violation of personal data protection regulations by the Company. The Data Subject's claim for compensation for the incurred damage, in the opinion of the President of UODO, confirms that the risk assessment presented in the Company's letters in this matter does not take into account the perspective of the Company's Client, who, as a result of the violation of the protection of her personal data, has likely suffered non-material damage.

As indicated in Guidelines 9/2022, a breach of personal data protection may potentially lead to a number of negative consequences for the natural persons whose data is the subject of the breach. Among the possible consequences of the breach, the EROD mentions: physical harm, material or non-material damages. Examples of such damages include, among others: discrimination, identity theft or identity fraud, financial losses, damage to reputation, breach of confidentiality of personal data,

and significant economic or social harm. In this case, there is no doubt that due to the scope of the data covered by the subject breach of personal data protection, including the PESEL identification number along with the name and surname, there is a high probability of the occurrence of the aforementioned damages.

First and foremost, it should be emphasized that the breach of personal data protection involved the PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing, among other things: date of birth and gender designation, and thus is closely related to the private sphere of the natural person and is also subject to, as a national identification number, exceptional confidentiality.

protection under Article 87 of Regulation 2016/679 - which is data of a special nature and requires such special protection. The PESEL number serves as an identifier for each individual and is commonly used in dealings with various institutions and in legal transactions. The PESEL number, along with the first name and surname, unequivocally identifies a natural person in a way that allows for the assignment of negative consequences of a violation (e.g., identity theft, loan fraud) to that specific individual. Furthermore, it should be noted that as a result of the aforementioned violation of personal data protection, this registration number was disclosed to an unauthorized person along with the first name and surname of the Company's Client, which combination of data can be sufficient for "impersonating" the subject of that data and incurring obligations in the name of and to the detriment of that subject, e.g., financial obligations (see:

<https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusci> - where a case is described in which: "Only the first name, surname, and PESEL number were enough for fraudsters to defraud several loans totaling tens of thousands of zlotys. Nothing else matched: neither the ID number nor the residential address"). It is also impossible to overlook that the analyzed violation of personal data protection also concerned contact details, which are generally accepted to include the residential or temporary address and the phone number of the Company's Client, as well as her email address. In assessing the risk, a key factor is the type and sensitivity of the personal data disclosed as a result of the violation. In Guidelines 9/2022, it was emphasized that a collection of various personal data usually has a more sensitive nature than individual data. It is worth citing one of the examples found in the Guidelines of the European Data Protection Board 01/2021[2] (case no. 14, p. 31), relating to the situation of "accidentally mailing highly confidential personal data." In the case described in the aforementioned guidelines, there was a disclosure of a social security number, which is equivalent to the PESEL number used in Poland. In this case, the EDPB had no doubt that the disclosed data concerning: first name and surname, email address, postal address, and social security number indicated a high risk of violation of the rights or freedoms of natural persons ("the involvement of their [the affected persons] social security number, as well as other, more basic personal data, additionally increases the risk that can be described as high"). The EDPB recognizes the importance of national identification numbers (in this case, the PESEL number), while emphasizing that this type of personal data breach, therefore encompassing data in the form of: first name and surname, email address, postal address, and social security number, requires the implementation of actions, i.e., notifying the supervisory authority and informing the affected individuals about the breach. The European Data Protection Board has no doubt that an individually assigned number that unequivocally identifies a natural person should be subject to special protection, and its disclosure to unauthorized entities may be associated with a high risk of violation of the rights or freedoms of natural persons. The fact that data that unequivocally identifies a natural person may cause a high risk of violation of rights or freedoms is also indicated by the EDPB in other examples provided in Guidelines 01/2021. In points 65 and 66 of Guidelines 01/2021, it was indicated: "(...) The breached data allow for the unequivocal identification of the individuals to whom the data relates and contain other information about them (including gender, date and place of birth); moreover, they can be used by an attacker to guess customer passwords or to conduct a spear phishing campaign directed at bank customers. For these reasons, it was deemed that the data breach is likely to result in a high risk of violation of the rights and freedoms of all individuals whose data is concerned. Consequently, there may be material damages (e.g., financial losses) and non-material damages (e.g., identity theft or fraud)." Similar doubts (that the

disclosure of the PESEL number along with other personal data may cause a high risk of violation of the rights or freedoms of natural persons) were also held by the Provincial Administrative Court in Warsaw, which in its judgment of September 22, 2021, case file II SA/Wa 791/21, stated that "There is no doubt that the examples of damages cited in the guidelines may occur in the case of individuals whose personal data - in some cases together with the PESEL identification number or the series and number of the ID card - have been recorded on the disclosed recordings. Not without significance for such an assessment is the possibility of identifying individuals whose data has been subject to the breach based on the disclosed data." Furthermore, the Court in the cited ruling indicated that "The data was disclosed to unauthorized persons, which means that there was a breach of security leading to the unauthorized disclosure of personal data, and the scope of this data, which in some cases also includes the PESEL identification number or the series and number of the ID card, determines that there was a high risk of violation of the rights or freedoms of natural persons." Considering the above issues, it is also necessary to refer to the position of the Provincial Administrative Court in Warsaw expressed in the judgment of July 1, 2022, issued in case file II SA/Wa 4143/21. In the justification of this judgment, the Court stated that: "It should be agreed with the President of the UODO that the loss of confidentiality of the PESEL number in conjunction with personal data such as: first name and surname, residential address, bank account numbers, and the identification number assigned to Bank clients - the CIF number, is associated with a high risk of violation of the rights or freedoms of natural persons. In the case of a breach

such data as name, surname, and PESEL number, as there is a possibility of identity theft or forgery resulting in negative consequences for the individuals whose data is concerned. Therefore, the Bank should have promptly notified the individuals concerned about the breach of personal data protection, in accordance with Article 34(1) of the GDPR, so as to enable them to take necessary preventive actions" (emphasis added). It should also be noted the judgment of August 31, 2022, case file II SA/Wa 2993/21, in which the Provincial Administrative Court in Warsaw emphasized that "(...) the authority rightly concluded that there was a high risk of violation of the rights and freedoms of the individuals affected by the breach due to the possibility of easy identification of the individuals whose data was involved in the breach, based on the disclosed data. These data include name and surname, correspondence address, phone number, and PESEL number of individuals holding Polish citizenship. In this situation, the administrator was obliged to notify without undue delay the individuals concerned about the breach." The Provincial Administrative Court in Warsaw expressed similar views in judgments dated November 15, 2022, case file II SA/Wa 546/22, and June 21, 2023, case file II SA/Wa 150/23.

According to the latest infoDOK report[3] (which is prepared as part of the social Information Campaign of the RESTRICTED DOCUMENTS System, organized by the Polish Bank Association and some banks, under the patronage of the Ministry of Interior and Administration and in cooperation with, among others, the Police and the Consumers' Federation), there were 2,089 attempts to defraud loans and credits recorded in the third quarter of 2022. In the entire year of 2020, there were 6,884 attempts to defraud amounting to 253.8 million PLN, while in the entire year of 2021, there were 8,096 attempts to defraud loans totaling 336.6 million PLN. This means that the entire year of 2021 was significantly more dangerous in terms of the number of attempts at fraud and their amounts compared to the previous year: there was a 17% increase in the number of attempts at fraud and a 32% increase in the total amount of these attempts at fraud.

Moreover, as indicated by the case law, judgments in cases of loan fraud are not uncommon and have been issued by Polish courts in similar cases for a long time - for example, one can refer to the judgment of the District Court in Łęczyca dated July 27, 2016 (case file I C 566/15), in which the fraudsters taking a loan using someone else's data used a PESEL number, a fictitious address, and an incorrect ID number (invalid). In the justification of the aforementioned judgment, the Court stated that: "In this case, the plaintiff (...) based in W. acquired the receivable from (...) Limited Liability Company S.K.A. based in W. The party to the loan agreement dated May 5, 2014, was a person who unlawfully used the data of J. R. (...) The Limited Liability Company S.K.A. based in W. transferred the amount of 500 PLN to the indicated bank account. The key issue in this case was to establish that the defendant

did not enter into the loan agreement, which was a claim raised by the defendant throughout the proceedings. The conducted evidentiary proceedings and the analysis of documents submitted by the plaintiff lead to the conclusion that in the case at hand, the defendant was not a party to the loan agreement concluded on May 5, 2014. Although the PESEL number of the defendant J. R. was used in its conclusion, the indicated place of residence does not correspond to the place of residence of the defendant. The defendant J. R. has never lived in W. The loan amount was transferred to an account that was not owned by the defendant. At the time of the conclusion of the loan agreement, the ID number (...) had expired on March 15, 2014. The mobile phone number indicated in the loan agreement and its attachments does not match the actual phone numbers used by the defendant.

In the context of the case at hand, the Court found that the defendant demonstrated that they were not a party to the loan agreement that is the subject of these proceedings. Agreements concluded using means of distance communication should require detailed, thorough verification, and such verification conducted in this case leads to the conclusion that the defendant was not a party to the loan agreement.” It must also be noted that the Administrator's performance of their obligation arising from Article 34(1) of Regulation 2016/679 cannot be conditioned on the occurrence of a violation of the rights or freedoms of individuals whose data is concerned by the breach of personal data protection. The same applies to the obligation arising from Article 33(1) of Regulation 2016/679 - as stated by the Provincial Administrative Court in Warsaw in the judgment dated September 22, 2021, issued in case II SA/Wa 791/21: “It should be emphasized that the possible consequences of the event do not have to materialize. The content of Article 33(1) of Regulation 2016/679 indicates that the mere occurrence of a breach of personal data protection, which is associated with a risk of violation of the rights or freedoms of individuals, implies the obligation to report the breach to the relevant supervisory authority, unless it is unlikely that the breach will result in a risk of violation of the rights or freedoms of individuals” (and this Court similarly ruled in the previously mentioned judgment dated July 1, 2022, issued in case II SA/Wa 4143/21 and in judgments dated August 31, 2022, case II SA/Wa 2993/21, November 15, 2022, case II SA/Wa 546/22, and April 26, 2023, case II SA/Wa 1272/22).

When applying the provisions of Regulation 2016/679, it is necessary to keep in mind the purpose of this regulation (expressed in Article 1(2)), which is to protect the fundamental rights and freedoms of individuals, in particular their right to the protection of personal data.

In turn, the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of recital 1 of the preamble). In the event of any doubts, for example regarding the fulfillment of obligations by controllers – including in situations where there has been a breach of personal data protection – these values should be taken into account first and foremost.

It is worth emphasizing that when assessing the risk of infringement of the rights or freedoms of natural persons, which is a prerequisite for reporting a personal data breach and notifying the affected data subject, both the likelihood and the severity of potential negative consequences should be considered together. A high level of either of these factors affects the overall assessment, which determines the fulfillment of the obligations specified in Article 33(1) and Article 34(1) of Regulation 2016/679. Given that, due to the scope of the disclosed personal data, there was a possibility of serious negative consequences materializing for the data subject (as demonstrated above), the weight of the potential impact on the rights or freedoms of the natural person should be regarded as high. At the same time, the likelihood of high risk occurring as a result of the breach in question is not small and has not been eliminated. Therefore, it should be stated that in connection with the breach in question, there is a high risk of infringement of the rights or freedoms of the data subject, which consequently determines the obligation to report the personal data breach to the supervisory authority and to notify the data subject of the breach.

In Guidelines 9/2022, the EDPB indicates the factors to be considered when assessing risk, referring to recitals 75 and 76 of Regulation 2016/679, which suggest that the controller should take into account both the likelihood of occurrence and the severity of the threat to the rights or freedoms of the data subject. In the case of a personal data breach, the controller should focus on the risk arising from the breach's impact on the natural person. Thus, when assessing the risk to the natural person

resulting from the personal data breach, the controller should consider the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence. In this regard, when assessing risk, the EDPB recommends considering criteria such as: the type of breach, the nature, sensitivity, and amount of personal data, as well as the ease of identification, as these may affect the level of risk to natural persons. The risk of infringement of the rights and freedoms of the natural person, according to Guidelines 9/2022, will be greater when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases. The guidelines indicate that in case of any doubts, the controller should report the breach, even if such caution may seem excessive.

In summary of the above considerations, it should be stated that in this case there is a high risk of infringement of the rights or freedoms of the person affected by the breach, which in turn results in the Company having the obligation to report the personal data breach to the supervisory authority, in accordance with Article 33(1) of Regulation 2016/679, which must include the information specified in Article 33(3) of Regulation 2016/679, as well as to notify the data subject of the breach, in accordance with Article 34(1) of Regulation 2016/679, which must include the information specified in Article 34(2) of Regulation 2016/679. The Company, which due to the nature of its activities processes personal data on a large scale, should be aware of the legal obligations arising from the identification of a personal data breach. Informing the Controller of the obligations related to personal data protection, as well as advising the Controller, is also part of the tasks of the appointed data protection officer within the Company. The Company should also possess knowledge in this regard due to a previously issued decision imposing an administrative fine for the infringement of Article 33(1) of Regulation 2016/679, consisting of the failure to report the personal data breach to the President of the UODO (decision dated February 11, 2021, ref. DKN.5131.7.2020.111638), especially since the Controller's complaint against this decision was dismissed by a final judgment of the Provincial Administrative Court in W. dated [...] January 2022 (ref. II SA/Wa 1353/21).

Referring to the obligation of the Controller specified in Article 34(2) of Regulation 2016/679, the President of the UODO stated that the Controller (considering the nature of the breach and the categories of data that were breached) should indicate to the data subject the most likely negative consequences of the breach of their personal data. Certainly, in the case of a breach of such data as first name, last name, and PESEL identification number, it is necessary to primarily point out the possible theft or falsification of identity through obtaining loans from non-bank institutions or fraudulently obtaining insurance or funds from insurance, which may lead to negative consequences related to the attempt to attribute responsibility for such fraud to the data subject. The description of possible consequences should reflect the risk of infringement of the rights or freedoms of that person, so as to enable them to take necessary preventive actions.

In a situation where, as a result of a personal data breach, there is a high risk of infringement of the rights or freedoms of natural persons, the controller...

is obliged to implement all appropriate technical and organizational measures to promptly identify a personal data breach and quickly inform the supervisory authority as well as the data subjects. The controller should fulfill this obligation as soon as possible.

Recital 85 of the preamble to Regulation 2016/679 states: "In the absence of appropriate and timely action, a personal data breach may result in physical harm, material or non-material damage to individuals, such as loss of control over their personal data or limitation of rights, discrimination, identity theft or fraud, financial loss, unauthorized reversal of pseudonymization, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, or any other significant economic or social damage. Therefore, immediately after becoming aware of a personal data breach, the controller should notify the supervisory authority without undue delay, and where feasible, no later than 72 hours after becoming aware of the breach, unless the controller can demonstrate in accordance with the principle of accountability that the breach is unlikely to result in a risk to the rights or freedoms of natural persons. If it is not possible to notify within 72 hours, the notification should be accompanied by an explanation for the delay, and the information may be provided gradually, without

further undue delay.”

Furthermore, Recital 86 of the preamble to Regulation 2016/679 indicates: “The controller should inform the data subject without undue delay of a personal data breach if it is likely to result in a high risk to the rights or freedoms of that individual, in order to enable that individual to take the necessary protective measures. Such information should include a description of the nature of the personal data breach and recommendations for the data subject on minimizing the potential adverse effects. Information should be communicated to the data subjects as soon as reasonably feasible, in close cooperation with the supervisory authority, respecting the guidance provided by that authority or other relevant bodies, such as law enforcement. For example, the need to minimize the immediate risk of harm will require prompt notification of the data subjects, while the implementation of appropriate measures against similar or analogous personal data breaches may justify a later notification.”

By notifying the data subject without undue delay, the controller enables the individual to take the necessary protective measures to safeguard their rights or freedoms against the negative effects of the breach. Article 34(1) and (2) of Regulation 2016/679 aims not only to ensure the most effective protection of the fundamental rights or freedoms of data subjects but also to implement the principle of transparency, which arises from Article 5(1)(a) of Regulation 2016/679 (see Witold Chomiczewski [in:] GDPR. General Data Protection Regulation. Commentary, ed. E. Bielak-Jomaa, D. Lubasz, Warsaw 2018). Proper fulfillment of the obligation specified in Article 34 of Regulation 2016/679 is intended to provide data subjects with prompt and transparent information about the breach of their personal data, along with a description of the possible consequences of the personal data breach and the measures they can take to minimize its potential negative effects. By acting in accordance with the law and demonstrating care for the interests of the data subjects, the controller should have promptly provided the data subjects with the best possible protection of their personal data. To achieve this goal, it is essential at least to indicate the information listed in Article 34(2) of Regulation 2016/679, which the controller failed to fulfill. Therefore, by deciding not to notify the supervisory authority as well as the data subject about the breach, the controller effectively deprived the Data Subject of timely, reliable information about the personal data breach and the opportunity to counteract potential damages.

Consequently, it must be stated that the Controller did not report the personal data breach to the supervisory authority in fulfillment of the obligation under Article 33(1) of Regulation 2016/679 and did not notify the data subject without undue delay about the breach of their data, in accordance with Article 34(1) of Regulation 2016/679, which constitutes a violation of these provisions by the Controller.

At this point, it should be noted that according to Article 34(4) of Regulation 2016/679, if the controller has not yet notified the data subject about the personal data breach, the supervisory authority—taking into account the likelihood that the personal data breach will result in a high risk—may require the controller to do so or may determine that one of the conditions referred to in paragraph 3 has been met. Furthermore, from the content of Article 58(2)(e) of Regulation 2016/679, it follows that each supervisory authority has the corrective power to order the controller to notify the data subject about the personal data breach.

According to Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2) of Regulation 2016/679, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. The President of the UODO states that in the case at hand, there were grounds...

justifying the imposition of an administrative monetary penalty on the Company based on Article 83(4)(a) of Regulation 2016/679, which states, among other things, that a breach of the obligations of the controller referred to in Articles 33 and 34 of Regulation 2016/679 is subject to an administrative monetary penalty of up to 10,000,000 EURO, and in the case of an enterprise - up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

According to the provisions of Article 83(2) of Regulation 2016/679, administrative monetary penalties are imposed, depending on the circumstances of each individual case, in addition to or instead of the

measures referred to in Article 58(2)(a) - (h) and (j) of Regulation 2016/679. In deciding to impose an administrative monetary penalty on the Company, the President of the UODO - in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 - took into account the following circumstances of the case, which necessitate the application of this type of sanction in the present case and which have an aggravating effect on the amount of the imposed administrative monetary penalty:

1. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing in question, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679).

In this case, a breach of Article 33(1) of Regulation 2016/679 was identified (consisting of the failure to notify the President of the Office for Personal Data Protection of the personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach) as well as Article 34(1) of Regulation 2016/679 (consisting of the failure to inform the affected individual of the personal data breach without undue delay). These breaches are related to an incident involving the disclosure to an unauthorized person of a contract containing the personal data of the Company's Client in the form of: PESEL number along with the first name and surname and contact details, as well as an email address, which makes it significant and serious, as this incident could lead to material or non-material damage to the individual whose data was breached, and the likelihood of such damage occurring is high. It should also be emphasized that from the letter dated [...] January 2023, which the District Court in P. sent to the President of the UODO, it follows that the Company's Client has made a claim for damages due to the breach of personal data protection regulations by the Company. The Data Subject's claim for compensation for the damage suffered, in the opinion of the President of the UODO, only confirms that the risk assessment presented in the Company's letters in this matter considers only the perspective of the Controller, which means that it does not take into account the perspective of the Company's Client, who, as a result of the breach of her personal data, has likely suffered non-material damage.

In this case, it was established that the breach concerned the personal data of one individual. Such a number of individuals affected by the breach, especially given the fact that the Company - due to the scale and scope of its operations - processes the personal data of a very large number of clients, should be considered small, which undoubtedly works in favor of the Controller. However, this does not affect the overall assessment of the impact of this criterion - as an aggravating factor - on the amount of the imposed penalty.

The President of the UODO considers the long duration of the Company's breach of the provisions of Regulation 2016/679 to be an aggravating circumstance. From the moment the Controller became aware of the breach, i.e., [...] November 2020, when a letter from the Client's attorney was delivered to him, until the date of this decision, almost three years have passed, during which the risk of infringement of the rights or freedoms of the affected individual could have materialized, and to which that individual could not have countered due to the Company's failure to fulfill the obligation to notify the President of the UODO of the personal data breach and the obligation to inform the affected individual.

2. The intentional nature of the breach (Article 83(2)(b) of Regulation 2016/679).

According to the Guidelines of the Article 29 Working Party on the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by EROD on May 25, 2018), intent "includes both knowledge and deliberate action, in connection with the characteristics of the prohibited act." The Company made a conscious decision not to notify the President of the UODO, as well as the individual whose data were concerned, about the breach. There is no doubt that the Company, processing personal data on a large scale, must have knowledge in the field of personal data protection, including knowledge of the consequences of identifying a personal data breach resulting in a high risk of infringement of the rights or freedoms of individuals (and such knowledge can be required not only from the controller but also

from the data protection officer appointed by him). Undoubtedly, the source of knowledge for the Company regarding the obligations related to the breach of personal data protection is also the decision of the President of the Office for Personal Data Protection dated February 11, 2021 (described below in point 3), against which the Company's complaint was dismissed by a final judgment of the Provincial Administrative Court in Warsaw on January 21, 2022 (case file II SA/Wa 1353/21). The administrative monetary penalty imposed by the aforementioned decision, along with a comprehensive justification in which the President of the UODO cited applicable provisions and guidelines, contains necessary information about the obligations of the Controller related to the identified breach of personal data protection. It can therefore be concluded that the Controller, being aware...

the administrator of any actions aimed at minimizing the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679).

2. The degree of responsibility of the controller (Article 83(2)(d) of Regulation 2016/679).

The controller's actions, which led to the data breach, demonstrate a significant degree of negligence in fulfilling their obligations under data protection law. The failure to report the data breach to the President of the UODO and to notify the affected individuals indicates a disregard for the responsibilities imposed by the regulation.

3. Any relevant previous infringements by the controller or processor (Article 83(2)(e) of Regulation 2016/679).

The President of the UODO had previously conducted administrative proceedings against the Company (described further in this section) regarding a breach of the obligation arising from Article 33(1) of Regulation 2016/679 due to the failure to notify the supervisory authority of a personal data breach within 72 hours of its discovery. By decision dated February 11, 2021, reference number DKN.5131.7.2020.111638, the President of the UODO imposed an administrative fine of PLN 136,437 on the Company for violating this provision of Regulation 2016/679. The aforementioned decision, as mentioned in point 2, was upheld by a judgment of the Provincial Administrative Court in W. dated [...] January 2022, dismissing the complaint. The repeated violation of the provisions of Regulation 2016/679 by failing to notify the President of the UODO of the identified personal data breach demonstrates the Company's dismissive approach to its obligations related to personal data processing, trivializing the incident and failing to recognize its impact on the Data Subject. The violation of the provisions of Regulation 2016/679, which is the subject of these proceedings, is not a one-time occurrence, and deserves a negative assessment, which is reflected in the imposition of an administrative fine on the Company.

4. The degree of cooperation with the supervisory authority to remedy the infringement and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679).

In this case, the President of the UODO found the cooperation from the Company to be unsatisfactory. This assessment pertains to the Administrator's response to the letters from the President of the UODO informing about the obligations imposed on the administrator in connection with the data breach, as well as regarding the initiation of administrative proceedings concerning the obligation to report the personal data breach and notify the affected individual. The actions deemed correct by the President of the UODO (reporting the breach to the President of the UODO and notifying the affected individual) were not undertaken by the Company even after the President of the UODO initiated administrative proceedings in the matter.

5. Categories of personal data affected by the infringement (Article 83(2)(g) of Regulation 2016/679).

The personal data disclosed to an unauthorized person do not belong to the special categories of personal data referred to in Article 9 of Regulation 2016/679; however, the fact that the disclosed agreement between the parties contained a wide range of data (name and surname, contact details, email address, PESEL identification number, and data related to the conclusion of the agreement and its content) is associated with a high risk of infringing the rights or freedoms of natural persons. The PESEL number, which is an eleven-digit numerical symbol uniquely identifying a natural person, containing the date of birth, ordinal number, gender designation, and control number, is thus closely

linked to the private sphere of the individual and is also subject, as a national identification number, to special protection under Article 87 of Regulation 2016/679, requiring such special protection. There is no other, so specific data that would unequivocally identify a natural person. It is not without reason that the PESEL number serves as an identifying data for every individual and is commonly used in dealings with various institutions and in legal transactions. The PESEL number, along with the name and surname, unequivocally identifies a natural person, allowing for the attribution of negative consequences of the breach (e.g., identity theft, loan fraud) to that specific individual.

In determining the amount of the administrative fine, the President of the UODO found no grounds to consider mitigating circumstances affecting the final amount of the fine. All the criteria listed in Article 83(2)(a)-(j) of Regulation 2016/679, in the assessment of the supervisory authority, constitute either aggravating factors or are merely neutral. Also, applying the criterion mentioned in Article 83(2)(k) of Regulation 2016/679 (which requires taking into account any other aggravating or mitigating factors applicable to the circumstances of the case), no mitigating circumstances were found, only neutral ones (as noted below in point 6 regarding financial benefits gained directly or indirectly in connection with the infringement or losses avoided).

Other circumstances indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified infringement in this case, were deemed neutral by the President of the UODO, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative fine:

1. Actions taken by the administrator to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679).

Based on the evidence gathered in the case, no actions were found to have been taken by the administrator aimed at minimizing the damage suffered by the data subjects.

****Administrator's Actions.****

2. ****Degree of Responsibility of the Administrator Considering the Technical and Organizational Measures Implemented by Him Pursuant to Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679).****

The violation of the provisions of Regulation 2016/679 assessed in this proceeding (failure to notify the President of the Personal Data Protection Office about the personal data breach and failure to inform the data subjects about the personal data breach) is not related to the technical and organizational measures applied by the administrator.

3. ****How the Supervisory Authority Became Aware of the Breach (Article 83(2)(h) of Regulation 2016/679).****

The President of the Personal Data Protection Office was not informed about the personal data breach that is the subject of this case in accordance with the procedure provided for such situations as specified in Article 33 of Regulation 2016/679. The President of the Personal Data Protection Office was informed about the occurrence of the breach related to the event involving the Administrator's disclosure of a contract containing personal data to an unauthorized recipient by the District Court in P., before which proceedings are ongoing initiated by the Company's Client regarding a claim for violation of personal data protection regulations. The lack of notification to the supervisory authority about the personal data breach and the failure to inform the data subject about the personal data breach is the sole subject of this proceeding, and in the circumstances of the considered factual state, the supervisory authority has accepted that it will not treat this circumstance as an aggravating factor.

4. ****Compliance with Previously Applied Measures in the Same Case as Mentioned in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679).****

Before issuing this decision, the President of the Personal Data Protection Office did not apply any measures against the Administrator in the case under consideration as listed in Article 58(2) of Regulation 2016/679, which means that the Administrator had no obligation to take any actions related to their implementation, and such actions, assessed by the President of the Personal Data Protection Office, could have had an aggravating or mitigating effect on the assessment of the established violation.

5. ****Application of Approved Codes of Conduct Pursuant to Article 40 of Regulation 2016/679 or Approved Certification Mechanisms Pursuant to Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679).****

The Administrator does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for administrators and processors, as stipulated by the provisions of Regulation 2016/679, which means that the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Administrator.

6. ****Financial Benefits Achieved Directly or Indirectly in Connection with the Breach or Losses Avoided (Article 83(2)(k) of Regulation 2016/679).****

The President of the Personal Data Protection Office did not find that the Administrator had gained any financial benefits or avoided such losses in connection with the breach. Therefore, there are no grounds to treat this circumstance as aggravating for the Administrator. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. However, the failure of the Administrator to achieve such benefits, as a natural state independent of the breach and its consequences, is a circumstance that, by its nature, cannot be mitigating for the Administrator. This is confirmed by the wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" - those that occurred on the part of the entity committing the breach. The President of the Personal Data Protection Office does not see any other aggravating or mitigating factors applicable to the circumstances of this case.

In the opinion of the President of the Personal Data Protection Office, the administrative fine imposed fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportionate, and deterrent in this individual case.

Considering the administrative fine imposed on the Company by the previous decision of the President of the Personal Data Protection Office (ref. DKN.5131.7.2020), it should be accepted that its amount was not effective; therefore, the President of the Personal Data Protection Office decided to increase the amount of the fine imposed by this decision. The fine will be effective if its imposition leads to the Company, which processes personal data professionally and on a large scale, fulfilling its obligations regarding personal data protection in the future, particularly in terms of reporting personal data breaches to the President of the Personal Data Protection Office and notifying the data subjects about the personal data breaches.

In the opinion of the President of the Personal Data Protection Office, the administrative fine will serve a repressive function, as it will be a response to the Company's violation of the provisions of Regulation 2016/679. It will also serve a preventive function; in the opinion of the President of the Personal Data Protection Office, it will indicate to both the Company and other data controllers the reprehensibility of neglecting the obligations of controllers related to the occurrence of a breach.

****Personal Data Protection****

aimed at preventing its negative and often painful consequences for the individuals affected by the violation, as well as removing these consequences or at least limiting them.

Pursuant to Article 103 of the Act of May 10, 2018 on Personal Data Protection (Journal of Laws of 2019, item 1781), hereinafter referred to as "uodo", the equivalent amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in Polish zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year - according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

Taking the above into account, the President of UODO, based on Article 83(4)(a) in connection with Article 103 of uodo, imposed on the Company - applying the average euro exchange rate from January

30, 2023 (1 EUR = 4.7160 PLN) - an administrative monetary penalty in the amount of 282,960 PLN (which constitutes the equivalent of 60,000 EUR).

In the opinion of the President of UODO, the imposed monetary penalty of 282,960 PLN (in words: two hundred eighty-two thousand nine hundred sixty zlotys) meets the criteria referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the established violation in the context of the fundamental purpose of Regulation 2016/679 - the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data.

Referring to the amount of the administrative monetary penalty imposed on the Company, the President of UODO considered that it is proportional to the financial situation of the Administrator and will not constitute an excessive burden for him. The financial report presented by the Administrator indicates that the Company's net sales revenue in 2022 amounted to 12,395,706,000 PLN, which means that the amount of the administrative monetary penalty imposed in this case constitutes approximately 0.002% of the aforementioned revenue.

At the same time, it is worth emphasizing that the amount of the imposed penalty of 282,960.00 PLN is only about 0.11% of the maximum penalty that the President of UODO could impose on the Company for the violations established in this case, applying the maximum penalty of up to 2% of the total annual turnover from the previous financial year (i.e. 247,917,120 PLN) in accordance with Article 83(4) of Regulation 2016/679.

The amount of the penalty was determined at such a level that, on the one hand, it constitutes an adequate response of the supervisory authority to the degree of violation of the administrator's obligations, and on the other hand, it does not create a situation in which the necessity to pay the financial penalty would result in negative consequences, in the form of significant job reductions or a substantial decrease in the Company's turnover.

In the opinion of the President of UODO, the Company should and is able to bear the consequences of its negligence in the area of data protection, as evidenced by the financial report of the Company submitted to the President of UODO on May 26, 2023.

In this factual and legal state, the President of the Office for Personal Data Protection decided as stated in the operative part.

The decision is final. The party has the right to appeal the decision to the Provincial Administrative Court in Warsaw within 30 days from the date of its delivery, through the President of the Office for Personal Data Protection (address: ul. Stawki 2, 00-193 Warsaw). A fee must be paid for the appeal in accordance with Article 231 in connection with Article 233 of the Act of August 30, 2002 on Proceedings Before Administrative Courts (Journal of Laws of 2023, item 259). The party (natural person, legal person, or other organizational unit without legal personality) has the right to apply for legal aid, which includes exemption from court fees and the appointment of a lawyer, legal advisor, tax advisor, or patent attorney. Legal aid may be granted upon the request of the party submitted before the initiation of the proceedings or during the proceedings. The application is exempt from court fees.

According to Article 105(1) of uodo, the administrative monetary penalty must be paid within 14 days from the expiration of the deadline for filing an appeal to the Provincial Administrative Court, or from the day the administrative court's ruling becomes final, to the bank account of the Office for Personal Data Protection at NBP O/O Warsaw no. 28 1010 1010 0028 8622 3100 0000.

Furthermore, according to Article 105(2) of the aforementioned Act, the President of the Office for Personal Data Protection may, upon a justified request from the penalized entity, postpone the deadline for payment of the administrative monetary penalty or allow it to be paid in installments. In the case of postponing the deadline for payment of the administrative monetary penalty or allowing it to be paid in installments, the President of the Office for Personal Data Protection calculates interest on the unpaid amount at an annual rate, applying a reduced late payment interest rate announced based on Article 56d of the Act of August 29, 1997 - Tax Ordinance (Journal of Laws of 2022, item 2651, as amended), from the day following the day of submission of the request.

According to Article 74 of uodo, the filing of an appeal by the party to the administrative court suspends the execution of the decision regarding the administrative monetary penalty.

[1] The aforementioned guidelines updated and supplemented the Guidelines of the Article 29 Working Party on reporting personal data breaches in accordance with Regulation 2016/679 (Wp250 rev.01), adopted on October 3, 2017.

[2] Guidelines of the European Data Protection Board 01/2021 on examples regarding notification of personal data breaches adopted on December 14, 2021, version 2.0 (hereinafter "EDPB Guidelines 01/2021").

[3] <https://www.zbp.pl/getmedia/731d1b29-3b2d-4dcf-9310-20aec2923725/infodok-2022-07-09-wydanie-51-sklad-221025-gk06>

Print Article

Metadata

Provider:

Department of Control and Violations

Created by:

Jan Nowak

2023-11-30

Entered by:

Agnieszka Pyka

2023-12-28 12:04:47

Last modified by:

Edyta Madziar

2024-05-24 11:07:42